

CT275: CÔNG NGHỆ WEB

Quy định và Tiêu chí đánh giá dự án

Bùi Võ Quốc Bảo

Học kỳ 3, 2025-2026

Xây dựng một website với PHP

- Sinh viên tự đề xuất dự án, một vài gợi ý:
 - ✓ Trang web review sách, quán cà phê, phim, ...
 - ✓ Trang web quản lý
 - ✓ Trang web thương mại điện tử
 - ✓ ...

Quy định về dự án

- Mã nguồn dự án **PHẢI** được quản lý bởi git và lưu trên GitHub và có lịch sử commit
- **KHÔNG** sử dụng một framework hoàn chỉnh như Laravel
- Sinh viên **CHỈ SỬ DỤNG** các công nghệ/công cụ/kỹ thuật được giới thiệu trong học phần (Bootstrap/Tailwind, JavaScript, PHP, PDO, Composer, SSE, MVC)
 - ✓ Có thể sử dụng các thư viện trên packagist thông qua composer

Các tiêu chí đánh giá cho dự án

Thành phần đánh giá \ Mức đạt*	1 (0%)	2 (25%)	3 (50%)	4 (75%)	5 (100%)
Xây dựng các trang web dùng Bootstrap	0	0.5	1	1.5	2
Dùng PHP và PDO tạo trang web động phía server có tương tác với CSDL (đọc/thêm/sửa/xóa)	0	0.5	1	1.5	2
Sử dụng phù hợp các công cụ giúp tổ chức mã lệnh trong dự án PHP (PHP include, lập trình hướng đối tượng, tự động nạp lớp, Composer, MVC)	0	0.5	1	1.5	2
Đề phòng các lỗi bảo mật thường gặp (XSS, SQL injection, CSRF, IDOR, chứng thực) cho trang web	0	0.5	1	1.5	2
Cài đặt các tính năng nâng cao: upload tập tin, HTTP caching, SSE	0	0.5		1.0	
Cấu hình web server phù hợp để vận hành website	0	0.5		1.0	

*Các mức độ đạt của sinh viên được đánh giá dựa trên *sản phẩm kết quả, file báo cáo và vấn đáp*

Các tiêu chí đánh giá cho dự án

- Tiêu chí chung cho các thành phần đánh giá
 - ✓ Mã lệnh sao chép y hệt từ nguồn khác có thể làm hạ mức đạt
 - ✓ Mã lệnh hoạt động đúng, ít lỗi
 - ✓ Trả lời chính xác các câu hỏi liên quan
- Xây dựng các trang web dùng Bootstrap
 - ✓ Số lượng trang web ≥ 6 được xây dựng với Bootstrap 5, các trang có cấu trúc trang đầy đủ và có liên kết giữa các trang
 - ✓ Sử dụng đa dạng các thành phần và tính năng của Bootstrap 5
 - ✓ Khuyến khích thiết kế web hiển thị tốt trên thiết bị di động

Các tiêu chí đánh giá cho dự án

- Dùng PHP và PDO tạo trang web động phía server có tương tác với CSDL (đọc/thêm/sửa/xóa)
 - ✓ Thực hiện đúng quy trình xử lý yêu cầu HTTP (từ giai đoạn đọc tham số đến tạo nội dung trả lời). Số lượng trang web kết xuất phía server ≥ 6
 - ✓ Đọc dữ liệu từ CSDL ra trang web với số lượng bảng dữ liệu từ 4-6 bảng, có ít nhất một mối quan hệ giữa các bảng
 - ✓ Sử dụng biểu mẫu (form) nhận nhập liệu từ người dùng và cập nhật dữ liệu (thêm/sửa/xóa) vào CSDL
 - ✓ Các tác vụ tương tác với CSDL cần liên quan đến các chức năng xử lý quy trình nghiệp vụ

Các tiêu chí đánh giá cho dự án

- Sử dụng phù hợp các công cụ giúp tổ chức mã lệnh dự án PHP (PHP include, lập trình hướng đối tượng, tự động nạp lớp, Composer, MVC)
 - ✓ Website có một thư mục riêng dùng làm Document Root (các tên thông thường của thư mục này là *public*, *www*, *htdocs*, ...). Khuyến khích tổ chức dự án theo MVC với URL “sạch” (/products, /products/123, ...)
 - ✓ Nếu dùng include/require thì các script được include/require phải được bảo vệ ngăn truy cập trực tiếp từ người dùng* (ví dụ như tổ chức các script này nằm ở ngoài thư mục Document Root)
 - ✓ Nếu có tạo lớp thì PHẢI thực hiện tự động nạp lớp theo chuẩn PSR-4 (có thể dùng Composer để quản lý tự động nạp lớp)
 - ✓ Nếu sử dụng mã lệnh/thư viện bên ngoài thì dùng Composer để quản lý

*<https://stackoverflow.com/questions/409496/prevent-direct-access-to-a-php-include-file>

Các tiêu chí đánh giá cho dự án

- Đề phòng các lỗi bảo mật thường gặp (XSS, SQL Injection, CSRF, IDOR, chứng thực) cho trang web
 - ✓ Đề phòng XSS: dùng các hàm có sẵn của PHP như *htmlspecialchars()* hoặc một template engine
 - ✓ Đề phòng SQL Injection: dùng *Prepared Statement* của PDO với tham số giữ chỗ (*:varname* hoặc *?*) khi thực thi câu lệnh SQL
 - ✓ Đề phòng CSRF: tạo session key đính kèm vào các form và kiểm tra session key khi form được gửi về
 - ✓ Đề phòng IDOR: kiểm tra quyền người dùng trên các đối tượng truy xuất
 - ✓ Chứng thực người dùng với tài khoản username/password cục bộ hoặc OAuth2/OpenID Connect

Các tiêu chí đánh giá cho dự án

- Cài đặt các tính năng nâng cao: upload tập tin, HTTP caching, Server-sent Event (SSE)
 - ✓ Cài đặt từ 2 trong 3 tính năng sau đây trở lên: xử lý upload tập tin, vận dụng header ETag/Last-Modified kết hợp với câu trả lời 304 Not Modified để tối ưu lưu lượng mạng, cập nhật nội dung web thời gian thực với SSE

Các tiêu chí đánh giá cho dự án

- Cấu hình web server phù hợp để vận hành website
 - ✓ Cấu hình web server cho website với HTTP2/HTTPS cục bộ hoặc triển khai website với tên miền công khai (VPS, Cloudflare Tunnel, ...)
 - ✓ Cấu hình HTTP caching phù hợp cho tài nguyên tĩnh và tài nguyên động (dùng các header như ETag, Last-Modified, Cache-Control, ...)